

CITY UNIVERSITY OF HONG KONG

Course code & title : CS5285 Information Security for eCommerce

Session : Semester A 2013/14

Time allowed : Two hours

This paper has FIVE pages (including this cover page).

1. This paper consists of 5 questions.
 2. Answer ALL FIVE questions.
 3. Total: 100 points
-

*This is a **closed-book** examination.*

Candidates are allowed to use the following materials/aids:

Approved Calculators

Materials/aids other than those stated above are not permitted. Candidates will be subject to disciplinary action if any unauthorized materials or aids are found on them.

**NOT TO BE
TAKEN AWAY**

**NOT TO BE TAKEN AWAY
BUT FORWARDED TO LIB**

Remark: Give concise reasons and show key steps in each problem. Keep your answers and reasons brief and right-to-the-point.

1. Computer Security (20 points):

(a) (6 points)

In each of the following scenarios, identify the type of malicious program that a host is being attacked by. (1) A program replicates itself in a very fast pace and severely slows down the host. (2) A program starts erasing data in a hard drive when the date becomes April 1st while the program does not infect any executable files. (3) A program emails a copy of itself to a subset of email addresses obtained from an address book stored in the host and starts erasing data in a hard drive when the date becomes April 1st. (4) A program monitors all HTTP GET messages sent out from the host and emails a copy of the messages to *trapdoor@whatever.email.net*.

(b) (8 points)

In a system, each user has an entry in the system's password file: (y, s) where y is computed as follows and s is a salt.

- i. $y = H(\text{password}, s)$ where H is SHA-1
- ii. $y = H(s, \text{password}) \oplus \text{password}$
- iii. $y = H(s) \oplus H(\text{password})$
- iv. $y = E(s, \text{password})$ where E is AES and the first input of E is the key
- v. $y = E(\text{password}, s)$
- vi. $y = E(s, H(\text{password}))$
- vii. $y = \text{MAC}(s, \text{password})$ where MAC is HMAC and the first input of MAC is the key
- viii. $y = \text{MAC}(\text{password}, s)$

List which of the methods above for computing y are secure against (precomputed) dictionary attack. Assume that s is 40 bits long and randomly chosen.

(c) (6 points)

Consider the following fragment in an authentication program.

```
username = read_username();
password = read_password();
if username is "122t-h4ck0r"
return ALLOW_LOGIN;
if usernmae and password are valid
return ALLOW_LOGIN
else return DENY_LOGIN
```

What type of malicious software is this? Use at most five sentences to explain your answer.



2. Public Key Cryptography (20 points):

(a) (10 points)

Given a public key $Y = 11$, a prime $p = 13$ and a generator $g = 2$ for a multiplicative group $Z_p^* = \{1, 2, \dots, p-1\}$. Suppose a ciphertext is (A, B) where $A = 5$, $B = 5$, and is computed using ElGamal Encryption, that is, $A = g^r \bmod p$, $B = MY^r \bmod p$ for some random number $r \in Z_{p-1}$ where $Z_{p-1} = \{0, 1, \dots, p-2\}$. Find message M .

(b) (5 points)

Let $H(x) = g^x \bmod p$. Use at most 5 sentences to explain why H is not collision resistant. If $H(x) = 3^x \bmod 23$, find two distinct inputs x and y such that $H(x) = H(y)$ and the values of x and y must be greater than 100.

(c) (5 points)

Find the expected number of messages that a bruteforce attacker has to try for breaking the collision resistance of the hash function H below. Represent your result in 2's power.

$$H(x) = \text{SHA}(\text{MD5}(x) \parallel \text{MD5}(x) \parallel \text{MD5}(x)).$$

3. SSL, IKE, IPSec (20 points):

(a) (5 points)

Consider the SSL protocol below (with $K = h(S, R_A, R_B)$).

1. $A \rightarrow B : R_A$
2. $A \leftarrow B : \text{Cert}_B, R_B$
3. $A \rightarrow B : \{S\}_B, E(K, h(\text{msgs} \parallel K))$
4. $A \leftarrow B : h(\text{msgs} \parallel K)$
5. $A \leftrightarrow B : \text{Data encrypted under } K$

If we remove message 1, set $K = h(S, R_B)$ and change message 3 to

$$3. A \rightarrow B : \{S \parallel h(\text{msgs})\}_B$$

Use at most 5 sentences to explain whether this revised protocol is more susceptible to denial of service attacks or not.

(b) (10 points)

Consider the following key exchange protocol which is similar to IKE Phase 1 Aggressive Mode. p is a large prime number and g is a generator of Z_p^* .

1. $A \rightarrow B : g^a \bmod p, \{\text{"Alice"}\}_{Bob}, \{R_A\}_{Bob}$
2. $A \leftarrow B : g^b \bmod p, \{\text{"Bob"}\}_{Alice}, \{R_B\}_{Alice}, \text{proof}_B$
3. $A \rightarrow B : \text{proof}_A$

where

$$\text{proof}_A = h(g^{ab} \bmod p, g^a \bmod p, g^b \bmod p, \text{"Alice"})$$

$$\text{proof}_B = h(g^{ab} \bmod p, g^b \bmod p, g^a \bmod p, \text{"Bob"})$$

Identify the components of challenge and response for A to authenticate B and the components of challenge and response for B to authenticate A . Then modify the protocol so that R_A and R_B can be eliminated without weakening the security of the protocol. In your modification, no additional message protocol, secret keys or signature can be used.

(c) (5 points)

Consider the following simplified IKE Phase 1 in Aggressive Mode.

$A \rightarrow B$: "Alice", "Bob", $g^a \bmod p$

$A \leftarrow B$: "Bob", "Alice", $g^b \bmod p$, $[g^a \bmod p]_B$

$A \rightarrow B$: "Alice", "Bob", $[g^b \bmod p, g^a \bmod p]_A$

$[X]_A$ denotes a signature on message X generated by A . The session key established between A and B is $g^{ab} \bmod p$. Show that this simplified version is insecure against man-in-the-middle attack. Hint: consider that this IPSec system has multiple users.

4. Modes of Operations and Message Authentication (20 points):

(a) (5 points)

Let $E(K, M)$ be the AES encryption of message M under key K . Suppose CBC is used and M could be longer than 128 bits. Let H be a hash function. Alice wants to send some secret information to Bob. To ensure data confidentiality and message authentication, Alice is to choose one of the two approaches below.

Approach 1: Send $E(K, H(M))$ to Bob

Approach 2: Send $E(K, M) \parallel E(K, H(M))$ to Bob

where the symbol $\parallel$ represents binary string concatenation. After doing some security analysis, Alice finds that one approach is flawed. Identify the flawed one and use at most 5 sentences to explain why it is flawed.

(b) (5 points)

Suppose you have a file encrypted using AES in CBC mode. Draw a decryption block diagram (show the decryption of three ciphertext blocks in the diagram). There are 100 blocks of ciphertext created. Suppose you want to decrypt the 20th ciphertext block. How many blocks of ciphertext do you actually need to decrypt? Which blocks of ciphertext are they?

(c) (5 points)

Suppose you have a 100-block message encrypted using AES in CTR mode. Suppose you want to insert one new message block in between the original 79th and 80th plaintext blocks. How many blocks of ciphertext do you need to encrypt or re-encrypt? Which blocks are they?

(d) (5 points)

Consider the following mode of operation for a block cipher.

$$C_1 = IV \oplus E(K, P_1)$$

...

$$C_i = C_{i-1} \oplus E(K, P_i)$$

Give the equations of the corresponding decryption, and identify two weaknesses of this mode of operation.

5. Mutual Authentication and Key Exchange (20 points):

(a) (5 points)

Describe a two-message-flow key exchange protocol between two parties, Alice and Bob, such that the protocol achieves Perfect Forward Secrecy. Assume that the adversary is passive.

(b) (5 points)

Given the following protocol:

$A \rightarrow B$: "I'm Alice", R

$A \leftarrow B$: $[R, K]_{Bob}$

$A \rightarrow B$: $[R + 1, K]_{Alice}$

where R and K are nonces, and $[X]_{Alice}$ represents the signature generated by Alice. Modify the protocol so that it supports session key establishment with Perfect Forward Secrecy. In your modification, you cannot introduce any additional long-term keys for Alice or Bob.

(c) (5 points)

In GSM authentication, one of SRES and RAND is only 32 bits long while the other one is required to be 128 bits long. Identify the one which requires only 32 bits and the one which requires 128 bits. Also find out the probability that an active adversary is able to guess the value of SRES correctly.

(d) (5 points)

Besides the following challenge-response method which can be used for one-way authentication, describe four other methods which only use symmetric key cryptographic techniques. You may use E (for symmetric key encryption), MAC (for message authentication code), and D (for symmetric key decryption).

$A \rightarrow B$: N

$A \leftarrow B$: $H(K, N)$

where N is a nonce and $H(K, N)$ denotes the hash of the concatenation of a symmetric key K pre-shared between A and B , and the nonce N . The protocol above allows A to authenticate B .

The End